

GUÍA DE PROYECTO: OPERACIÓN "TOTAL PWNAGE"

Auditoría Integral, Defensa en Profundidad y Calidad del Software (DevSecOps)

Asignatura: Calidad, Seguridad y Auditoría Informática

Curso: Máster en Ingeniería Informática 2025

Modalidad: Parejas (Competitiva - Topología de Anillo Ciego)

1. DESCRIPCIÓN Y OBJETIVOS

Este proyecto simula un escenario de Guerra Cibernética Asimétrica en un entorno corporativo. Los estudiantes asumirán el ciclo de vida completo de un activo digital crítico: desde su desarrollo asistido por Inteligencia Artificial (IA), pasando por su despliegue y fortificación, hasta su defensa activa y auditoría post-incidente.

Objetivo General:

Desarrollar, auditar y defender un sistema web vulnerable sobre infraestructura Windows Server 2025. Los estudiantes competirán bajo un Acuerdo de Nivel de Servicio (SLA) estricto, donde la integridad, confidencialidad y disponibilidad del sistema impactan directamente en la calificación.

Topología "Anillo Ciego":

La práctica se realiza en un esquema rotatorio donde cada equipo ataca a un objetivo distinto al que le defiende (Equipo A -> Equipo B -> Equipo C -> Equipo A). La colusión está prohibida.

Las herramientas y los distintos marcos son sugerencias y guías pero los estudiantes elegirán los que consideren y justificarán su elección.

2. MARCO OPERATIVO Y FASES

FASE 0: DESARROLLO AGÉNTICO Y QA

Objetivo: Generar el activo a defender utilizando herramientas de programación agéntica, priorizando la seguridad desde el diseño (*Secure by Design*).

- **Ingeniería de Prompts:** Utilizar agentes de IA para generar una aplicación Web CRUD completa (PHP/ASP.NET/Python) con roles diferenciados (Admin/Cliente).
- **Auditoría de Código (QA):** Revisar el código generado por la IA. El prompt debe solicitar explícitamente medidas de seguridad (consultas preparadas, saneamiento de inputs), pero es responsabilidad de los estudiantes verificar que la IA no haya introducido vulnerabilidades o "alucinaciones" inseguras.
- **Entregable:** Código fuente y el "Prompt Maestro" utilizado en sus correspondientes anexos

Tecnología / Herramientas	Marco Normativo de Referencia
Antigravity, Cursor, GitHub Copilot	OWASP Top 10 (Prevención de riesgos web)
SonarLint, PHPStan	ISO/IEC 25010 (Calidad del producto software)

FASE 1: DESPLIEGUE, HARDENING Y DEFENSA PREVENTIVA

Objetivo: Fortificar el sistema operativo y establecer la línea base de auditoría *antes* de la entrega. El sistema se entregará como "Caja Negra" (sin credenciales).

- **Infraestructura:**
 - Desplegar Windows Server 2025 (Evaluation). [Descargar aquí:](https://www.microsoft.com/es-mx/evalcenter/download-windows-server-2025) <https://www.microsoft.com/es-mx/evalcenter/download-windows-server-2025>
 - Configurar IIS/Apache y SQL Express.
 - **Red:** Configuración obligatoria en modo "**Red de Solo Anfitrión**" (**Host-Only**) en el segmento 192.168.56.0/24. IP Estática oculta.
- **Hardening (Defensa en Profundidad):**
 - **Seguridad Física (Virtual):** Habilitar BitLocker (con TPM virtual) para cifrar el disco y evitar montajes externos. Establecer contraseña de BIOS/EFI para bloquear el arranque desde USB/CD.
 - **Seguridad Lógica:** Configurar Firewall para denegar todo tráfico excepto HTTP/HTTPS.
- **Monitorización (SIEM/EDR):**
 - Desplegar agente **Wazuh** o configurar **Sysmon** con reglas avanzadas para detectar ejecuciones sospechosas (*webshells*, movimiento lateral).

Tecnología / Herramientas	Marco Normativo de Referencia
Windows Server 2025, PowerShell DSC	CIS Benchmarks (Guías de Hardening)
Wazuh, Sysmon	NIST SP 800-53 (Controles SI-4: Monitorización)
BitLocker (TPM 2.0)	RGPD / GDPR (Art. 32: Cifrado de datos)

Forzosamente la máquina estará lista para ser transferida al RED TEAM el día 3 de marzo. Cada equipo deberá entregar un USB con la máquina (este USB será devuelto al final de la fase 2 con la máquina en el estado post-ataque) o un enlace para descargarla al BLUE TEAM, por cada día de demora se perderán 0,5 puntos de la nota final de la práctica.

FASE 2: PENTESTING "SIN CUARTEL" (RED TEAM)

Objetivo: Comprometer la máquina rival mediante cualquier vector disponible (Lógico o Físico).

- **Reconocimiento:** Descubrimiento de activos en la red ciega (`netdiscover`, `arp-scan`).
- **Vectores de Ataque Permitidos:**
 - **Vector Lógico:** Explotación de vulnerabilidades en la Web (SQLi, XSS, RCE) o servicios mal configurados.
 - **Vector Físico/Infraestructura:** Intentar eludir la BIOS, atacar el cifrado BitLocker, manipulación de la VM (*Evil Maid Attack*), reseteo de contraseñas offline (si el disco no está cifrado).
- **Condición de Victoria (Flag):** Obtener una shell como `NT AUTHORITY\SYSTEM` o exfiltrar la base de datos de usuarios.

Tecnología / Herramientas	Marco Normativo de Referencia
Nmap, Wireshark, Burp Suite	PTES (Penetration Testing Execution Standard)
Metasploit, SQLMap, Hydra	MITRE ATT&CK (Tácticas y Técnicas)
Chnptw, Lazesoft (Ataque Físico)	OSSTMM (Manual de Metodología de Seguridad)

La máquina volverá al Blue Team el día 7 de abril con las mismas penalizaciones ya mencionadas.

FASE 3: ANÁLISIS FORENSE POST-INCIDENTE (BLUE TEAM)

Objetivo: Reconstruir la "Kill Chain" del ataque recibido utilizando la evidencia digital.

- **Análisis:** Utilizar los logs centralizados en **Wazuh** o los eventos locales de Windows para determinar:
 1. Vector de entrada (¿Fallo Web o Físico?).
 2. Cronología del ataque.
 3. Alcance del compromiso (Datos exfiltrados, persistencia).

Tecnología / Herramientas	Marco Normativo de Referencia
Wazuh Dashboard (Kibana), Event Viewer	ISO/IEC 27037 (Evidencia Digital)
Autopsy, FTK Imager	RFC 3227 (Orden de volatilidad)

FASE 4: SECURIZACIÓN REACTIVA Y CALIDAD (Semana 7)

Objetivo: Cerrar la brecha y mejorar el proceso de desarrollo.

- **Análisis de Causa Raíz (RCA):** Determinar si el fallo fue producto de un mal Prompt a la IA, falta de revisión humana o configuración deficiente del OS.
- **Remediación:** Refactorizar el código, aplicar parches y endurecer las políticas de seguridad.
- **Métricas de Calidad:** Definir KPIs para monitorizar la seguridad del código futuro.

Tecnología / Herramientas	Marco Normativo de Referencia
SonarQube (SAST)	CWE (Common Weakness Enumeration)
OpenSCAP	NIST CSF (Función: Recuperar/Proteger)

3. SISTEMA DE EVALUACIÓN Y SLA (10 PUNTOS)

La evaluación se basa en un sistema de créditos de negocio. Los incidentes de seguridad y la necesidad de consultoría externa penalizan la calificación final.

Desglose de Puntuación Base:

- **Fase 0 y 1 (Desarrollo y Despliegue):** 1.5 Puntos
- **Fase 2 (Pentesting Ofensivo):** 2.5 Puntos
- **Fase 3 (Forense Defensivo):** 2.0 Puntos
- **Fase 4 (Securización y Calidad):** 2.0 Puntos
- **Fase 5 (Documentación y Prompting):** 2.0 Puntos

Matriz de Penalizaciones y Bonificaciones (SLA):

Evento de Seguridad	Impacto Blue Team (Defensa)	Impacto Red Team (Ataque)
Defensa Exitosa (Sistema íntegro)	+2.0 Puntos (Bonus)	0 Puntos
Hackeo "Físico" (Acceso por ISO/BIOS/BitLocker)	-1.5 Puntos (Negligencia Grave)	+1.5 Puntos (Easy Win)
Hackeo Web/Lógico (SQLi, RCE, Admin Access)	-1.0 Punto (Fallo de Software)	+1.5 Puntos (Mérito Técnico)
Exfiltración de Datos (Data Breach)	-1.0 Punto (Multa Regulatoria)	+1.0 Punto
Solicitud de Pista (RFI) (Consultoría Técnica)	+0.5 Puntos (Ingreso Consultoría)	-0.5 Puntos (Coste Operativo)
Denegación de Servicio Destructiva (VM rota)	0 Puntos	-1.0 Punto (Mala praxis)

4. REGLAS DE ENFRENTAMIENTO (RoE)

1. **Integridad de la VM:** Está prohibido modificar la configuración de hardware de la máquina virtual (RAM, CPU) desde el hipervisor, salvo para intentar el arranque por medios extraíbles (CD/USB) como parte de la simulación de ataque físico.

2. **Juego Limpio:** La colusión entre equipos atacantes y defensores para pactar vulnerabilidades resultará en el suspenso inmediato de ambos grupos.
3. **Gestión de Pistas (RFI):** Todas las pistas deben solicitarse formalmente mediante un "Request for Information". El equipo defensor está obligado a responder con veracidad técnica; mentir en un RFI se considera obstrucción a la auditoría.

Máster en Ingeniería Informática 2025 – Documento de Práctica Oficial